



STANDARD OPERATING PROCEDURE

Cashflow Dashboard

What every screen is, who uses it and why, where its data comes from, and the HIPAA safeguards protecting it — verified, not assumed.

PREPARED FOR

Sports Med Recovery

SYSTEM

cfovaani.in

VERSION

1.0

DATE

18 July 2026

HIPAA safeguards: 13 of 13 verified in production

Patient names never leave the ERP. Every login is individual and hashed, every read of patient data is recorded, all traffic is encrypted, and nothing identifying reaches QuickBooks. A single command re-proves all of it on demand.

Three administrative steps remain to complete formal compliance — listed in section 8.

01 Purpose & scope

The Cashflow Dashboard is a financial console over Sports Med Recovery's Striven ERP. It answers four questions the ERP makes slow to answer — **what are we owed, what do we owe, what is moving, and what is stuck** — and posts approved invoices into QuickBooks Online without re-keying.

ITEM	DETAIL
Who uses it	Practice owner, finance/admin staff, and the external accountant. Three named accounts today.
System of record	Striven ERP. The dashboard reads, shapes and posts — it never becomes the source of truth.
Refresh	Cached in Supabase, refreshed automatically every 6 hours; each screen also has a manual refresh.
Out of scope	Clinical notes, diagnoses, imaging, insurance IDs, dates of birth, addresses.

The design rule behind everything

No patient name ever leaves Striven. Every screen, every export and every record posted to QuickBooks refers to a patient as PT-418 — a reference built from their Striven customer id. Staff who need the actual name look it up in Striven, where access is already controlled. This single decision is what keeps the dashboard, the database and the accounting system free of patient identifiers.

02 Getting in — access procedure

STEP	WHAT HAPPENS
1. Open	Go to <code>https://cfovaani.in</code> from a bookmark — never from a link in an email.
2. Log in	Your own username and password. Accounts are personal.
3. Session	Lasts 12 hours. Lock your screen whenever you step away.
4. Log out	Use Log out on a shared or unfamiliar device.

Enforced by the system, not just written down

CONTROL	BEHAVIOUR
Password storage	script-hashed. Even with full database access, passwords cannot be read.
Failed attempts	5 wrong passwords in 15 minutes locks that account for 15 minutes.
Identity	Each session token is signed and names one user. There is no shared login.
Audit	Every login and every read of patient-derived data is recorded with user, page, IP and time.
Failure mode	If the user directory is unreachable the gate refuses everyone rather than falling back to a weaker credential.

Adding or removing a user

1. The Security Officer approves in writing, naming the person and the business reason.
2. The maintainer adds a row to `dashboard_users` with a hashed password.
3. The password is delivered out-of-band; the user completes training before first login.
4. **On departure:** delete the row the same day. To end a live session immediately, rotate `SESSION_SECRET` — this logs everyone out and is the correct move for any non-amicable exit.

03 The nine screens — what each is for

Left sidebar, top to bottom. "Patient data" below means data derived from a patient's orders shown against a PT– reference — never a name.

1 Overview

Patient data (referenced)

WHAT	Executive summary — cash position, revenue and expense trend, AR and AP headlines, the invoices and bills that need attention now.
USE CASE	The Monday-morning screen. Owner opens it to see whether cash is moving and what is overdue, without opening anything else.
SOURCE	/api/status , /api/trends , /api/ar , /api/ap
HIPAA	Invoice rows show a PT– reference and the payer (a law firm, VA or TriCare). No names.

2 AR / AP

Patient data (referenced)

WHAT	Two sub-views. Receivables — every open invoice, aged current / 1–30 / 31–60 / 61–90 / 90+, with unapplied credits and voided amounts separated out. Payables — the same for supplier bills.
USE CASE	Collections and payment runs. "Who do we chase this week, and what must we pay before it goes overdue."
SOURCE	/api/ar , /api/ap
HIPAA	Invoice amounts and dates against PT– references — protected data, correctly pseudonymised.

3 P&L

No patient identifiers

WHAT	Revenue, expenses and net profit by period, broken down by account.
USE CASE	Month-end review and the accountant's starting point. Answers "did we make money, and where did it go."
SOURCE	/api/pl
HIPAA	Aggregate financial totals only — nothing traceable to an individual.

4 Orders

Patient data (referenced)

WHAT	Two sub-views. Orders — every sales order with type (PI / VA / TriCare), sales rep, payer, value and whether it has been invoiced. Tracking — the order chain, following each sales order through to its purchase orders and invoices.
USE CASE	Revenue leakage. An order that was delivered but never invoiced is money already spent and never billed — this is where it surfaces.
SOURCE	/api/orders , /api/so , /api/po
HIPAA	Order rows carry a PT– reference. The Sales Rep and Payer columns hold business names — a rep or a law firm — verified as containing no patient identities.

5 Vendors & Items

No patient data

WHAT	Two sub-views. Vendors — supplier list with spend and payment terms. Catalog — the item/product master.
USE CASE	Purchasing and negotiation. "How much do we spend with this supplier, and on what."
SOURCE	/api/vendors , /api/items
HIPAA	Purely commercial data. Out of scope.

6 Accounts

No patient identifiers

WHAT Chart of accounts with balances, plus customer payments received and bill payments made.

USE CASE Reconciliation — matching what the ledger says against what actually moved.

SOURCE `/api/accounts` , `/api/payments` , `/api/billpayments`

HIPAA Ledger-level. Payments carry references, not names.

7 Exceptions

Patient data (referenced)

WHAT Everything that does not add up, grouped: orders with no invoice, purchase orders with no matching sales order, unapplied credits, amount mismatches. Each group opens into the underlying rows.

USE CASE The clean-up worklist — the screen that finds money. Around 25 unlinked purchase orders worth roughly \$50,494 currently sit here awaiting review.

SOURCE `/api/exceptions`

HIPAA Drill-down rows show PT– references.

8 Reports

Treat exports as protected

WHAT Two sub-views. **Vendor purchases** — what we buy from each supplier, built from purchase orders. **Patient orders** — what each patient reference orders, built from sales orders, ranked by order count. Cancelled orders are excluded from both. CSV export available.

USE CASE Buying patterns and supplier negotiation on one side; product demand by patient cohort on the other.

SOURCE `/api/reports/vendor-items` , `/api/reports/patient-items`

HIPAA On screen this is safe — references only. An exported CSV should be treated as protected: keep it on an encrypted work device, do not email it outside SMR, and delete it when the task is done.

9 QuickBooks

References only

WHAT Four numbered steps — Customers, Vendors, Items, Invoices — each showing exactly what exists in Striven but not yet in QuickBooks, with the option to create missing records individually, in a selection, or all at once. Invoices preview before posting.

USE CASE Removes double data entry between Striven and the accounts, and keeps the two reconciled.

SOURCE `/api/qb/*` (OAuth 2.0 to QuickBooks Online)

HIPAA Customers are created as PT– references and each invoice carries the reference, the original date and the amount — no name, no clinical detail. Verified: all 8 QuickBooks customers are references.

04 Procedure: posting to QuickBooks

Run in order. Each step only shows what is genuinely missing, so a step with nothing listed is already reconciled and can be skipped.

STEP	ACTION	WHY THE ORDER MATTERS
1 · Customers	Review the Striven customers missing from QuickBooks. Create all, or tick a selection.	An invoice cannot post without its customer. Created as PT– references.
2 · Vendors	Same, for suppliers.	Needed before any bill or purchase-side record.
3 · Items	Same, for products and services.	Invoice lines reference items; missing items fail the post.
4 · Invoices	Filter Pending / Posted / All. Preview an invoice, confirm, then post — singly, as a selection, or all pending.	Final step, once the three above are clean.

Two behaviours worth knowing

- **Dates are preserved.** A posted invoice carries its *original* Striven date, not the date you clicked post — so the accounts stay in the correct period.
- **Nothing posts twice.** Posted invoices are tracked, so re-running a batch skips what is already in QuickBooks.

The one rule for this screen

Never send a patient name, date of birth, address, phone, email, diagnosis or clinical description to QuickBooks — no matter how convenient a future feature makes it. Intuit does not offer a Business Associate Agreement for QuickBooks Online, which is precisely why the integration was designed to send references and amounts only.

05 HIPAA safeguards in place

Each of the following is implemented, running in production, and re-checkable on demand by the procedure in section 6.

Individual identity

Every user has their own account and a signed session token naming them. No shared login or shared password exists anywhere in the system.

§164.312(a)(2)(i)

Passwords unreadable

Stored as script hashes with per-user random salts. No plaintext copy exists in the code, configuration, environment or secret vault.

§164.312(a)(2)(iv)

Full audit trail

Every login attempt and every read of patient-derived data is recorded with the user, the page, the IP address and the timestamp.

§164.312(b)

Minimum necessary

Patient names are stripped at every write. Only references reach the browser, the database and the accounting system.

§164.502(b)

Encrypted in transit

TLS enforced site-wide; plain HTTP is redirected. Session cookies are HttpOnly and Secure, so they cannot be read by scripts or sent unencrypted.

§164.312(e)(1)

Encrypted at rest

The Supabase database encrypts stored data with AES-256.

§164.312(a)(2)(iv)

Log-in monitoring

Five failed attempts within fifteen minutes locks the account, blocking password-guessing attacks.

§164.308(a)(5)(ii)(C)

Fails closed

If the user directory cannot be reached, every login is refused rather than falling back to a weaker credential. Access is never accidentally left open.

§164.312(a)(1)

Credentials isolated

All secrets are read server-side only. The browser never receives an API key, a database key or a credential of any kind.

§164.312(a)(1)

Nothing identifying at Intuit

QuickBooks holds references and amounts only — verified across all 8 customer records.

§164.502(e)

Written policies

Eight documents covering policies, risk analysis, incident response, retention, training and vendor agreements.

§164.316(a)

Documented risk analysis

Twenty-one risks identified and rated, each with an owner, a control and a target date.

§164.308(a)(1)(ii)(A)

Why the reference design matters — and what it does not do

Replacing names with references means a breach of the dashboard or the database would expose order amounts against codes, not identified patients. It also keeps QuickBooks entirely outside the protected-data chain. That is a genuine and substantial reduction in exposure.

It is worth stating clearly, because it is often misunderstood: this is **pseudonymisation, not de-identification**. SMR keeps the key in Striven, so the underlying data remains protected health information and the vendors that host it remain Business Associates. That is why the agreements in section 8 still matter.

06 Procedure: verifying the safeguards

Run monthly, and before shipping any change to login, cached data or the QuickBooks integration.

Step 1 — run the automated check

```
$ node scripts/hipaa-check.mjs

PASS A1 Passwords are hashed, never plaintext
PASS A3 Unauthenticated requests are refused
PASS A4 A forged session token is rejected
PASS A6 Brute force is locked out
PASS A7 Session cookies are HttpOnly + Secure
PASS B2 Every read of patient data is attributed to a user
PASS C1 No patient name is stored in the database
PASS C3 QuickBooks holds no patient name
PASS D1 Site is served over TLS only
```

Technical controls: **13/13 PASS**

Safe to run at any time — it is read-only, and the lockout test uses a throwaway username so it can never lock a colleague out. A failure prints the exact location of the problem.

Step 2 — review the audit logs

```
-- failed logins in the last 30 days
select username, ip, at from login_events
where success = false and at > now() - interval '30 days' order by at desc;

-- who read patient data, and how much
select username, count(*), min(at), max(at) from phi_access_events
where at > now() - interval '30 days' group by username order by 2 desc;
```

Look for logins by departed staff, unfamiliar locations, bursts of failures, or a volume far outside someone's normal pattern. Record that the review happened even when nothing was found — the record is what an auditor asks for.

Step 3 — confirm the standing items

Vendor agreements current · training register up to date · user list matches actual staff · risk analysis reviewed within twelve months.

07 Daily rules for everyone with a login

DO	DO NOT
Log in only from an encrypted work device with a screen lock	Log in from a public, shared or hotel computer
Use a unique password of 12+ characters	Reuse a password from email or banking
Refer to patients by their PT- reference in email and chat	Share your login — every action is recorded against your name
Delete CSV exports as soon as the task is finished	Email or upload an export outside SMR
Reach the site from your bookmark	Paste dashboard data into ChatGPT, Claude or any unapproved online tool
Report anything odd the same day	Look up a patient, friend or colleague out of curiosity — every read is logged

If something goes wrong

Tell the Security Officer **the same day** — a lost device, a shared password, an export sent somewhere it should not have gone, a name appearing where a reference should be, or a login you do not recognise. Do not wait until you are sure it was real; fast reporting is what turns a breach into a near-miss, and there is no penalty for reporting in good faith. Full procedure: docs/hipaa/03-incident-response-plan.md .

08 To complete

The technical work is done and verified. What remains is administrative — signatures and one training session. None of it is engineering work, and all of it is achievable in a week.

#	ACTION	EFFORT	HOW
1	Sign Business Associate Agreements with Supabase, Vercel and Striven	Half a day	Supabase: Team plan + HIPAA add-on. Vercel: HIPAA add-on on Pro. Striven: a direct request — a ready-to-send email is prepared in 07-baa-action-pack.md
2	Name the Security & Privacy Officer in writing	10 minutes	Fill the blanks in 01-policies-and-procedures.md and the incident plan
3	Deliver training and sign the register	20 min / person	Material is written — 05-workforce-training.md
4	Add multi-factor authentication	90 days	The strongest available upgrade: lockout stops guessing, MFA stops a stolen password
5	Begin the monthly audit review	15 min / month	Section 6, step 2. First one due August 2026
6	Housekeeping: remove two retired environment variables; test a backup restore once	30 days	Both are precautionary — the retired values were already rotated and no longer work

Where this stands

The dashboard is built to HIPAA's technical standard, and — unusually — that claim is *verifiable*: one command re-proves all thirteen controls, so drift gets caught rather than assumed away. Patient names never leave the ERP, every access is attributed and logged, and the accounting system holds nothing identifying. Completing the three administrative items above closes the remaining distance to formal compliance.

Prepared by the system maintainer with AI assistance. This document records the system as built and verified on 18 July 2026. It is not legal advice and not a certification — a qualified HIPAA compliance professional should review it before it is relied upon in an audit, a payer contract or a breach response.